

HealthData Alliance BCR 审查报告草案

BCR-C 合规审查报告

审查对象：HealthData Alliance

审查范围：BCR Document-Driven Review (BCR-C)

审查日期：20260808

综合评级：高风险

关键发现

Binding nature (internal and external) 覆盖不完整；Third-party beneficiary rights 覆盖不完整；EU liable entity designation 覆盖不完整；Complaint handling mechanism 覆盖不完整；缺失 Cooperation with supervisory authorities

详细审查结果

检 查 项	主题	风 险	现状	整改建议	法律依据
BCR -C-1 .1	Binding nature (internal and external) 覆盖不完整	HIGH	Binding nature (internal and external) 部分覆盖但缺少关键要素. 依据：GDPR Article 47(1)(a), EDPB Recommendations 1/2022。证据：未提及集团内协议或其他具有法律约束力的内部文书	应补充 Binding nature (internal and external) 的完整内容。	GDPR Article 47(1)(a)；EDPB Recommendations 1/2022
BCR -C-1 .2	Third-party beneficiary rights 覆盖不完整	HIGH	Third-party beneficiary rights 部分覆盖但缺少关键要素. 依据：GDPR Article 47(1)(b), EDPB Recommendations 1/2022。证据：文本未包含数据主体可直接强制执行 BCR 的第三方受益人权利描述	应补充 Third-party beneficiary rights 的完整内容。	GDPR Article 47(1)(b)；EDPB Recommendations 1/2022

检 查 项	主题	风 险	现状	整改建议	法律依据
BCR -C-1 .3	EU liable entity designation 覆盖不完整	HIGH	EU liable entity designation 部分覆盖但 缺少关键要素. 依据：GDPR Article 47(2)(f), EDPB Recommendations 1/2022 。证据：未指定一个在 欧盟境内设立的实体作 为承担BCR合规责任的 主体	应补充 EU liable entity designation 的完整内容。	GDPR Article 47(2)(f) ; EDPB Recommendations 1/2022
BCR -C-1 .6	Complaint handling mechanism 覆盖不完整	MEDIUM	Complaint handling mechanism 部分覆盖但 缺少关键要素. 依据：GDPR Article 47(2)(e), EDPB Recommendations 1/2022 。证据：未明确投诉处 理的时限（如一个月内 ）	应补充 Complaint handling mechanism 的完整内容。	GDPR Article 47(2)(e) ; EDPB Recommendations 1/2022
BCR -C-1 .7	缺失 Cooperation with supervisory authorities	MEDIUM	未在文档中找到 Cooperation with supervisory authorities 的相关内容. 依据：GDPR Article 47(2)(f), EDPB Recommendations 1/2022。证据：	应补充 Cooperation with supervisory authorities 的完整内容。	GDPR Article 47(2)(f) ; EDPB Recommendations 1/2022
BCR -C-1 .8	Onward transfer restrictions 表述模糊	HIGH	Onward transfer restrictions 使用了模糊 表述，未达到具体可执 行标准. 依据：GDPR Chapter V, EDPB Recommendations 1/2022 。证据：使用'substantia lly similar'等笼统表述定 义保护标准，未指向具 体GDPR保护水平或SC C	应补充 Onward transfer restrictions 的完整内容。	GDPR Chapter V ; EDPB Recommendations 1/2022

检 查 项	主题	风 险	现状	整改建议	法律依据
BCR -C-1 .9	Third country law assessment (TIA) 覆盖不完整	HIGH	Third country law assessment (TIA) 部分覆 盖但缺少关键要素. 依据：Schrems II, EDPB 01/2020, EDPB Recommendations 01/202 0。证据：未说明使用E DPB六步法或其他结构 化方法进行TIA	应补充 Third country law assessment (TIA) 的完整内容。	Schrems II, EDPB 01/2020 ; EDPB Recommendations 01/2020
BCR -C-1 .10	缺失 Audit and training mechanisms	MEDIUM	未在文档中找到 Audit and training mechanisms 的相关内容. 依据：GDPR Article 47(2)(h), EDPB Recommendations 1/2022。证据：	应补充 Audit and training mechanisms 的完整内容。	GDPR Article 47(2)(h) ; EDPB Recommendations 1/2022
BCR -C-1 .12	Termination and exit provisions 覆盖不完整	MEDIUM	Termination and exit provisions 部分覆盖但缺 少关键要素. 依据：GDPR Article 47(2)(j), EDPB Recommendations 1/2022 。证据：命中关键词: ['end']	应补充 Termination and exit provisions 的完整内容。	GDPR Article 47(2)(j) ; EDPB Recommendations 1/2022
BCR -SH ARE D-2	Personal data breach notification 覆盖不完整	MEDIUM	Personal data breach notification 部分覆盖但 缺少关键要素. 依据：, GDPR Article 33, 34。证据：命中关键词: ['breach']	应补充 Personal data breach notification 的完整内容。	; GDPR Article 33, 34

高风险项目

Binding nature (internal and external) 覆盖不完整；Third-party beneficiary rights 覆盖不完整；EU liable entity designation 覆盖不完整；Onward transfer restrictions 表述模糊；Third country law assessment (TIA) 覆盖不完整；未明确指定 EU 责任主体；未赋予数据主体第三方受益人权利；转委托处理缺乏书面授权机制；缺少法律约束力文书具体说明

中风险项目

Complaint handling mechanism 覆盖不完整；缺失 Cooperation with supervisory authorities；缺失 Audit and training mechanisms；Termination and exit provisions 覆盖不完整；Personal data breach notification 覆盖不完整；Government access request handling 覆盖不完整；TIA 未引用 EDPB 结构化评估方法；TIA 缺少定期审查机制；TIA 未提及补充保护措施；TIA 缺少无法缓解风险时的中止条款；未明确限制向非 BCR 成员传输；缺少转委托授权机制；EU 责任主体未明确承诺责任/赔偿；缺少数据主体救济渠道说明；TIA 评估方法不够完整；投诉处理时限未明确；缺少子处理者变更通知机制

低风险项目

无

整改路线图

高风险项（需立即整改）：

- Binding nature (internal and external) 覆盖不完整
- Third-party beneficiary rights 覆盖不完整
- EU liable entity designation 覆盖不完整
- Onward transfer restrictions 表述模糊
- Third country law assessment (TIA) 覆盖不完整